

Lab Exercise 7.02: DNSSEC for Exploiting

1. Running **dig ns arin.net.** to get some information about the Authoritative DNS Servers for the arin.net domain:

```
(potato@kali)-[~]
$ dig ns arin.net.

; <<>> DiG 9.20.15-2-Debian <<>> ns arin.net.
;; global options: +cmd
;; Got answer:
;; -->HEADER<-- opcode: QUERY, status: NOERROR, id: 8984
;; flags: qr rd ra ad; QUERY: 1, ANSWER: 4, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags;; MBZ: 0x0005, udp: 512
;; QUESTION SECTION:
;arin.net.                IN      NS

;; ANSWER SECTION:
arin.net.                  5       IN      NS      ns3.arin.net.
arin.net.                  5       IN      NS      u.arin.net.
arin.net.                  5       IN      NS      ns2.arin.net.
arin.net.                  5       IN      NS      ns1.arin.net.

;; Query time: 43 msec
;; SERVER: 192.168.102.2#53(192.168.102.2) (UDP)
;; WHEN: Thu Apr 02 18:21:56 HST 2026
;; MSG SIZE rcvd: 107
```

2. Try an **external zone transfer**. In this case, we're going to ask one of the authoritative DNS servers for the arin.net zone for an AXFR of the entire zone:
dig axfr @ns1.arin.net arin.net.

```
(potato@kali)-[~]
$ dig axfr @ns1.arin.net arin.net.

; <<>> DiG 9.20.15-2-Debian <<>> axfr @ns1.arin.net arin.net.
; (2 servers found)
;; global options: +cmd
; Transfer failed.
```

- arin.net has allowed only authorized internal zone transfers from its DNS servers, so the message “Transfer failed” appears.

3. Try digging with a hostname that doesn't exist: **dig rit.arin.net.**

```
(potato@kali)-[~]
$ dig rit.arin.net.

; <<>> DiG 9.20.15-2-Debian <<>> rit.arin.net.
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NXDOMAIN, id: 11567
;; flags: qr rd ra ad; QUERY: 1, ANSWER: 0, AUTHORITY: 1, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; MBZ: 0x0005, udp: 512
;; QUESTION SECTION:
;rit.arin.net.                IN      A

;; AUTHORITY SECTION:
arin.net.                    5       IN      SOA     ns1.arin.net. bind.arin.net. 2021113585 10800 600 1209600 3600

;; Query time: 100 msec
;; SERVER: 192.168.102.2#53(192.168.102.2) (UDP)
;; WHEN: Thu Apr 02 18:28:20 HST 2026
;; MSG SIZE rcvd: 86
```

-Without the DNSSEC option, there is a nonexistent domain (NXDOMAIN) status in the response. When a resource record isn't specified, dig defaults to the A resource record type.

4. Now, with the DNSSEC option back, let's try a resource record that doesn't exist: **dig +dnssec rit.arin.net.**

```
(potato@kali)-[~]
$ dig +dnssec rit.arin.net.

; <<>> DiG 9.20.15-2-Debian <<>> +dnssec rit.arin.net.
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NXDOMAIN, id: 27219
;; flags: qr rd ra ad; QUERY: 1, ANSWER: 0, AUTHORITY: 5, ADDITIONAL: 0

;; QUESTION SECTION:
;rit.arin.net.                IN      A

;; AUTHORITY SECTION:
arin.net.                    5       IN      SOA     ns1.arin.net. bind.arin.net. 2021113585 10800 600 1209600 3600
arin.net.                    5       IN      RRSIG   SOA 8 2 43200 20260416120020 20260402110020 41655 arin.net. UPVb50C8lCuHc2zoc8UAFryQ79zOy1qmMwLNVigpeQeYct1cqh22ZEJ +pWSYH7twLh3PSYLuVTHqCCGaOch51D5id64qqXANVJClc
I/f3bhkuA/ M376SAPRUx54EYfX8FeSqW3yq2/FASWT1qlaxRoOnrUBKEECJl0cs2 C1k=
arin.net.                    5       IN      NSEC    _dmarrc.arin.net. A NS SOA MX TXT AAAA RRSIG NSEC DNSKEY CAA
arin.net.                    5       IN      RRSIG   NSEC 8 2 36000 20260416120020 20260402110020 41655 arin.net. CZNIWvy4TqoD2R7YNPU+AarMgt9GaAfxrS3Es1+Xv9KXjmtAmuaG16dA Nmkk1kC4qAspU4knKwnt/vv7OabgMonVWzjBduMdfImJab
N1611J2qWw 0hkjdktwD+M7/XarqychWaj516mDWLuZKaRtQ3/xm9Z/Wc+ESYlkyfJj Ang=
rtrns.arin.net.             5       IN      NSEC    rpki.arin.net. A AAAA RRSIG NSEC

;; Query time: 52 msec
;; SERVER: 192.168.102.2#53(192.168.102.2) (UDP)
;; WHEN: Thu Apr 02 18:34:21 HST 2026
;; MSG SIZE rcvd: 493
```

-Again, there is an NXDOMAIN status, but now you'll notice a **Next SECure (NSEC)** resource record that has ripe.arin.net. on the left and rpki.arin.net. on the right

5. When we try another name, we again get confirmation that the resource record doesn't exist, and again we are also told what legitimate resource records it falls between: **dig +dnssec jonathan.arin.net.**

```
(potato@kali):~$ dig +dnssec jonathan.arin.net.

;<>> DIG 9.28.15-2-Debian <>> +dnssec jonathan.arin.net.
;; global options: +cmd
;; Got answer:
;;->HEADER=< opcode: QUERY, status: NXDOMAIN, id: 29698
;; flags: qr rd ra ad; QUERY: 1, ANSWER: 0, AUTHORITY: 4, ADDITIONAL: 0

;; QUESTION SECTION:
jonathan.arin.net.                IN      A

;; AUTHORITY SECTION:
arin.net.                5      IN      SOA      ns1.arin.net. bind.arin.net. 2021113585 10800 600 1209600 3600
arin.net.                5      IN      RRSIG   SOA 8 2 43200 20260410120020 20260402110020 41655 arin.net. UPVbSOC8lCuHc2zoc8UAFRyQ79z0y1qmM0LnVigpeQeYct1cqH22ZEJ +pWSYH7twLh3PSYLuvThqCCGa0ch5lD5id64qqXANVJClc
I/f3bhkuAj M376SAPRUX54EYfxBFesQkWE3yq2/FASWT1qlaxRoOnRU8KEECJt0cs2 C1k=
arin.net.                5      IN      NSEC    _dmarc.arin.net. A NS SOA MX TXT AAAA RRSIG NSEC DNSKEY CAA
arin.net.                5      IN      RRSIG   NSEC 8 2 3600 20260410120020 20260402110020 41655 arin.net. CZN1Wvy4TqwD2R7YNPU+AarMgt9GaAfxrS3EsI+Xv9KKJmTAmuaG16dA Nmkk1kC4qAspU4knKwmt/vV70abgMonVnzjBduMdf1mJAb
Nl6l1J2qWw 0hkjdktwD+M7/XarqychWajS16mDWluzKaRtQ3/xn9Z/wc+e5Ylkyfj Ang=

;; Query time: 148 msec
;; SERVER: 192.168.102.2#53(192.168.102.2) (UDP)
;; WHEN: Thu Apr 02 18:38:58 HST 2026
;; MSG SIZE rcvd: 458
```

-We are told that jonathan.arin.net. doesn't exist and that it falls between jamf.arin.net. and kim-can.arin.net.

-If NXDOMAIN responses weren't authenticated and signed with DNSSEC, this would be an easy attack for cybercriminals to carry out. **For each query to a domain that supports DNSSEC, an NXDOMAIN response can be sent back before the actual answer from the legitimate DNS server, making domains simply disappear from the view of certain clients.**

6. Let's take the resource record that comes alphabetically after jonathan.arin.net. and add a character (which could actually be any character). Since jonathan.arin.net. falls between jamf.arin.net. and kim can.arin.net. alphabetically, enter the following command: **dig +dnssec kim-can1.arin.net.**

```
(potato@kali):~$ dig +dnssec kim-can1.arin.net.

;<>> DIG 9.28.15-2-Debian <>> +dnssec kim-can1.arin.net.
;; global options: +cmd
;; Got answer:
;;->HEADER=< opcode: QUERY, status: NXDOMAIN, id: 41252
;; flags: qr rd ra ad; QUERY: 1, ANSWER: 0, AUTHORITY: 5, ADDITIONAL: 0

;; QUESTION SECTION:
kim-can1.arin.net.              IN      A

;; AUTHORITY SECTION:
arin.net.                5      IN      SOA      ns1.arin.net. bind.arin.net. 2021113585 10800 600 1209600 3600
arin.net.                5      IN      RRSIG   SOA 8 2 43200 20260410120020 20260402110020 41655 arin.net. UPVbSOC8lCuHc2zoc8UAFRyQ79z0y1qmM0LnVigpeQeYct1cqH22ZEJ +pWSYH7twLh3PSYLuvThqCCGa0ch5lD5id64qqXANVJClc
I/f3bhkuAj M376SAPRUX54EYfxBFesQkWE3yq2/FASWT1qlaxRoOnRU8KEECJt0cs2 C1k=
arin.net.                5      IN      NSEC    _dmarc.arin.net. A NS SOA MX TXT AAAA RRSIG NSEC DNSKEY CAA
arin.net.                5      IN      RRSIG   NSEC 8 2 3600 20260410120020 20260402110020 41655 arin.net. CZN1Wvy4TqwD2R7YNPU+AarMgt9GaAfxrS3EsI+Xv9KKJmTAmuaG16dA Nmkk1kC4qAspU4knKwmt/vV70abgMonVnzjBduMdf1mJAb
Nl6l1J2qWw 0hkjdktwD+M7/XarqychWajS16mDWluzKaRtQ3/xn9Z/wc+e5Ylkyfj Ang=
kim-can.arin.net.        5      IN      NSEC    lacnic.arin.net. A RRSIG NSEC

;; Query time: 352 msec
;; SERVER: 192.168.102.2#53(192.168.102.2) (UDP)
;; WHEN: Thu Apr 02 18:43:09 HST 2026
;; MSG SIZE rcvd: 502
```

-The new output shows kim-can.arin.net. on the left, and lacnic.arin.net. on the right. We are now zone walking! By forcing the previous answer on the right to the left, we can continue this process and walk through all of the resource records of the zone, as if we successfully performed an external zone transfer as seen in Step 2.

7. Now, let's add a character to lacnic to force it on the left and see what the next resource record is: **dig +dnssec lacnic1.arin.net**.

```
(potato@kali) ~$ dig +dnssec lacnic1.arin.net.

;<>> DiG 9.20.15-2-Debian <>> +dnssec lacnic1.arin.net.
;; global options: +cmd
;; Got answer:
;;->HEADER=< opcode: QUERY, status: NXDOMAIN, id: 39181
;; flags: qr rd ra ad; QUERY: 1, ANSWER: 0, AUTHORITY: 5, ADDITIONAL: 0

;; QUESTION SECTION:
;lacnic1.arin.net.      IN      A

;; AUTHORITY SECTION:
arin.net.              5      IN      SOA      ns1.arin.net. bind.arin.net. 2021113585 10800 600 1209600 3600
arin.net.              5      IN      RRSIG   SOA 8 2 43200 20260416120020 20260402110820 41655 arin.net. UPVbSOC8lCuHc2zoc8UAFryQ79z0y1qmM4oLNVlpgpQeyct1cqhz2ZEJ +pWSYH7twLh3PSYLuVThqCCGaOch51D5id64qqXANVJClc
1/f3bnkuaJ M3765APRUX545yfxBF50kWE3yq2/fADWtIqla800hrU8KECf3tes2 Ckx
arin.net.              5      IN      NSEC    _marc.arin.net. A NS SOA MX TXT AAAA RRSIG NSEC DNSKEY CAA
arin.net.              5      IN      RRSIG   NSEC 8 2 3600 20260416120020 20260402110820 41655 arin.net. CZN1Wvy4TqwD2R7YWPu+AarMgt9GaAfxrS3EsI+Xv9KKJmTAmuaG16dA Nmkk1Kc4qAspU4knWmt/vV70abgMonVMz3BduMdf1m3Ab
N161IJ2qW 0hkjdktwD+W7/XarqychWa3s16mbWuzKaRtQ3/xm9Z/Wc+5YlkyfJ Ange
lacnic.arin.net.       5      IN      NSEC    lightning.arin.net. A AAAA RRSIG NSEC

;; Query time: 268 msec
;; SERVER: 192.168.102.2#53(192.168.102.2) (UDP)
;; WHEN: Thu Apr 02 18:46:29 HST 2026
;; MSG SIZE rcvd: 503
```

-The new output shows lacnic.arin.net. is on the left and lightning.arin.net. is on the right.

8. To combat this zone walking ability, the NSEC3 resource record was introduced. Some domains are set up to return NSEC3 resource records instead of NSEC records. The Internet Corporation for Assigned Names and Numbers (ICANN), the organization at the top of the hierarchy of Internet names and numbers, is one such example. Try: **dig +dnssec rit.icann.org**.

```
(potato@kali) ~$ dig +dnssec rit.icann.org.

;<>> DiG 9.20.15-2-Debian <>> +dnssec rit.icann.org.
;; global options: +cmd
;; Got answer:
;;->HEADER=< opcode: QUERY, status: NXDOMAIN, id: 25007
;; flags: qr rd ra ad; QUERY: 1, ANSWER: 0, AUTHORITY: 5, ADDITIONAL: 0

;; QUESTION SECTION:
;rit.icann.org.        IN      A

;; AUTHORITY SECTION:
icann.org.             5      IN      SOA      sns.dns.icann.org. noc.dns.icann.org. 2026040207 10800 3600 1209600 3600
91damu11st5dbb9qtKntegrashk0af.icann.org. 5 IN NSEC3 1 0 0 - 9LF17DR6VICMSVDAKET33CKBBLCHGD A NS SOA MX TXT AAAA RRSIG DNSKEY NSEC3PARAM CAA
ks3bo2nbyvndphkjsgbm+Jae8920he.icann.org. 5 IN NSEC3 1 0 0 - KSADQULQLTPlOB0uH1K0L64RQKt6PRAJ A RRSIG
buicc9acpumsJ2d4orvkkrmk7qrbgJ5g.icann.org. 5 IN NSEC3 1 0 0 - BUSM8PIACP27QL2URQD3V4R064TCR700 CNAME RRSIG
icann.org.             5      IN      RRSIG   SOA 13 2 3600 20260424091021 20260403014211 54015 icann.org. J4E73ocUDysYlkoNvjWNSHNFJby+ErR24pskbzL9/WK8G0PK0I8VEVvM ePPWYqG+Kke5Pdhx8HyvWqqsDYx1IA=

;; Query time: 46 msec
;; SERVER: 192.168.102.2#53(192.168.102.2) (UDP)
;; WHEN: Thu Apr 02 18:49:19 HST 2026
;; MSG SIZE rcvd: 425
```

-NSEC3 doesn't replace NSEC—in fact, both are used today. When NSEC3 is used, the incorrect name is hashed and compared to the hashes of the names in the zone.

NSEC3 doesn't return the actual names that come before and after, but instead, what hash comes before the hash of the name that doesn't exist and what hash comes after the hash of the name that doesn't exist.

-All the attacker needs to do now, to get the actual names, is an offline dictionary attack or brute force attack. Subdomains/hostnames are not that long. If an attacker precomputes a wordlist for all subdomains/hostnames of length 10 and below, a corresponding hash for each name will be stored. Now the attacker simply compares the two hashes in the NSEC3 resource record with the stored hashes to find out what

the subdomain/hostname is for each. Interestingly enough, three NSEC3 resource records will actually be returned, for reasons explained in sections 5.5 and 5.6 of RFC 712

-Of note for NSEC3 is that there is one salt (also coming up in Chapter 11) per zone and many hash iterations. An enhancement, NSEC3 White Lies, can help, but it requires signatures to be computed in real time, unlike the RRSIGs we've seen so far, which are precomputed. The NSEC3 resource record would take the hash of a nonexistent name, compute its hash, and respond that there are no resource records between the hash -1 and the hash +1. If the hash is c32d2, hash -1 is c32d1 and hash +1 is c32d3. Now no actual names, hashed or plaintext, are ever revealed. The only value between hash -1 and hash +1 is the hash of the nonexistent name.

Having on-demand signing requires private keys to be stored on a zone's authoritative servers. It also makes authoritative servers vulnerable to a denial of service (DoS) attack, since generating signatures is computationally intensive. Furthermore, on-demand signing could enable a chosen-plaintext attack to succeed

9. Let's take a look at another NSEC3 resource record, with different hashes: dig +dnssec jonathan.icann.org.

```
(potato@kali): ~$ dig +dnssec jonathan.icann.org.
<>>> DIG 9.20.15-2-Debian <>> +dnssec jonathan.icann.org.
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NXDOMAIN, id: 47136
;; flags: qr rd ra ad; QUERY: 1, ANSWER: 0, AUTHORITY: 5, ADDITIONAL: 0

;; QUESTION SECTION:
; jonathan.icann.org.                IN      A

;; AUTHORITY SECTION:
icann.org. 5 IN SOA sns.dns.icann.org. noc.dns.icann.org. 2026040208 10800 3600 1209600 3600
icann.org. 5 IN RRSIG SOA 13 2 3600 20260423170640 20260403034212 54015 icann.org. 4MMMS502EYs9DM5nOhmsOfzgLYwUmyyI475jpZg50qQuHPK8ZVUZWw04 cB6BPZF06uZnPj1oBHuH+HIFJCG0Hw==
9ldamU1ist5dbb9qtkntegrasihk0af.icann.org. 5 IN NSEC3 1 0 0 - 9LF70R0V10NSV0D4K7K33K48BLCH0D A NS SOA MX TXT AAAA RRSIG DNSKEY NSEC3PARAM CAA
9ldamU1ist5dbb9qtkntegrasihk0af.icann.org. 5 IN RRSIG NSEC3 13 3 3600 20260416004615 20260325231159 54015 icann.org. w3h2U177Id+GallrWg+psXngwR/O/cFjy46v8uodhDBF28n8EPTXDW5LF v9Qve3RQ1Mp58gN0G1CzFhwRYjMB8Q==
tsfKiskfqlQqrrlrzgegn7gmt8v4n72.icann.org. 5 IN NSEC3 1 0 0 - TSOIMV252NGM6T1EH4S44EU1I2U3A1UA CNAME RRSIG

;; Query time: 88 msec
;; SERVER: 192.168.102.2#53(192.168.102.2) (UDP)
;; WHEN: Thu Apr 02 18:52:54 HST 2026
;; MSG SIZE rcvd: 456
```

-Another hashing of the before and after resource records.